POLITECHNIKA ŚLĄSKA · WYDZIAŁ AUTOMATYKI, ELEKTRONIKI I INFORMATYKI

Bezpieczeństwo Aplikacji i Systemów Mobilnych

Zajęcia 1 · Wprowadzenie i wybór projektu

Mateusz Kawulok · rok akademicki 2026/27

ORGANIZACJA

Jak wygląda każde spotkanie (od zajęć 2)

15 min

Wprowadzenie

Zagrożenie, przykład ataku, obrona na każdej platformie

10 min

Arkusz sekcji

„Jak to dotyczy naszej aplikacji?”

60 min

Rundy po sekcjach

Ok. 10–12 min na sekcję: arkusz i postęp prac

15 min

Porównanie

Co daje platforma, gdzie było najtrudniej

5 min

Zadanie

Konkretny artefakt w repozytorium

Zasada: każdy temat ląduje w kodzie — zagrożenie → implementacja → dowód, że działa.

ORGANIZACJA

Harmonogram semestru

Nr	Temat	Etap
1	Wprowadzenie i wybór projektu	Start
2	Modelowanie zagrożeń i architektura	
3	Model bezpieczeństwa platform	
4	Bezpieczne przechowywanie danych	
5	Kryptografia	MVP
6	Uwierzytelnianie i sesje	
7	Komunikacja sieciowa	

Nr	Temat	Etap
8	Bezpieczeństwo backendu i API	Półmetek
9	Interakcje z platformą i walidacja wejścia	
10	Jakość kodu i łańcuch dostaw	
11	Inżynieria wsteczna i odporność	
12	Prywatność + audyt krzyżowy	Audyt
13	Prezentacje końcowe	Finał

ORGANIZACJA

Kamienie milowe i ocenianie

Z5 **MVP**
Działająca aplikacja z funkcjami z umowy, model zagrożeń v1

Z8 **Półmetek**
Model zagrożeń v2, status checklisty MASVS

Z12 **Audyt krzyżowy**
Raport z testów aplikacji innej sekcji

Z13 **Finał**
Prezentacja i checklista MASVS z dowodami

30%	Działająca aplikacja spełniająca umowę
30%	Dokumentacja bezpieczeństwa: model zagrożeń i checklista MASVS
20%	Audyt krzyżowy aplikacji innej sekcji
20%	Aktywność i artefakty z kolejnych spotkań

DLACZEGO BEZPIECZEŃSTWO MOBILNE

Czym różni się od aplikacji webowej

Urządzenie poza naszą kontrolą

Root, jailbreak, emulator, zmodyfikowany system — atakujący ma pełny dostęp do swojego telefonu.

Binarka trafia do każdego

APK i IPA można pobrać, zdekompilować i zmodyfikować. Sekret w kodzie nie jest sekretem.

Wiele wejść do aplikacji

Deep linki, intenty, powiadomienia push, schowek, WebView, inne aplikacje na tym samym urządzeniu.

Dane osobiste i sensory

Lokalizacja, zdjęcia, kontakty, biometria, zdrowie — i odpowiedzialność wynikająca z RODO.

DEMO · 3 MINUTY

Co widzi atakujący

1. Pobieramy APK celowo podatnej aplikacji (np. DIVA lub InsecureBankv2)
2. Otwieramy plik w jadx-gui
3. Szukamy: key, secret, password, http
4. Wszystko, co zapisano w kodzie, jest jawne

```
// zdekompilowany kod (przykład)
public final class ApiClient {
  String BASE_URL =
    "https://api.przyklad.pl/v1";
  String API_KEY =
    "sk_live_51H...xQ";
}
// ← widoczny dla każdego
```

MAPA ZAGROŻEŃ

OWASP Mobile Top 10 (2024)

M1	Niewłaściwe użycie danych uwierzytelniających
M2	Niewystarczające bezpieczeństwo łańcucha dostaw
M3	Niebezpieczne uwierzytelnianie i autoryzacja
M4	Niewystarczająca walidacja wejścia i wyjścia
M5	Niebezpieczna komunikacja
M6	Niewystarczająca ochrona prywatności
M7	Niewystarczająca ochrona pliku binarnego
M8	Błędna konfiguracja zabezpieczeń
M9	Niebezpieczne przechowywanie danych
M10	Niewystarczająca kryptografia

SZKIELET PRZEDMIOTU

OWASP MASVS — 8 obszarów, 8 tematów

MASVS-STORAGE

Przechowywanie danych

Zajęcia 4

MASVS-CRYPTO

Kryptografia

Zajęcia 5

MASVS-AUTH

Uwierzytelnianie

Zajęcia 6

MASVS-NETWORK

Komunikacja sieciowa

Zajęcia 7

MASVS-PLATFORM

Interakcje z platformą

Zajęcia 3 i 9

MASVS-CODE

Jakość kodu

Zajęcia 10

MASVS-RESILIENCE

Odporność na inżynierię wsteczną

Zajęcia 11

MASVS-PRIVACY

Prywatność

Zajęcia 12

MASVS mówi, co ma być spełnione. **MASTG** mówi, jak to przetestować. Na koniec oddajecie checklistę MASVS z dowodami.

PROJEKT

Umowa o powierzchni ataku

Temat jest dowolny — ale każdy projekt musi zawierać wszystkie poniższe funkcje.

Wymagana funkcja	Czego dotyczy	Zajęcia
Logowanie z tokenami i co najmniej dwie role	uwierzytelnianie, autoryzacja	6, 8
Własny backend/API lub Firebase/Supabase z regułami	sieć, bezpieczeństwo API	7, 8
Lokalne dane wrażliwe (tokeny, dane osobowe, cache)	przechowywanie, kryptografia	4, 5
Uprawnienie systemowe (kamera, lokalizacja, pliki, BLE)	model platformy, prywatność	3, 12
Deep link lub universal link	walidacja wejścia	9
WebView lub wczytywanie treści zewnętrznych	interakcje z platformą	9
Biometria jako opcja odblokowania	uwierzytelnianie	6

PROJEKT

Tematy startowe

Mini-bank / portfel P2P

Przelewy między użytkownikami, historia, limity.

Uczy: autoryzacji obiektów, integralności, biometrii

Dziennik zdrowia

Pacjent i lekarz, zdjęcia wyników badań.

Uczy: ochrony danych szczególnie wrażliwych, RODO

Bilety z kodem QR

Zakup, przekazanie, skanowanie przy wejściu.

Uczy: ochrony przed fałszowaniem, trybu offline

Sejf haseł i notatek

Synchronizacja między urządzeniami.

Uczy: kryptografii po stronie klienta, kluczy

Kontroler smart home

Parowanie i sterowanie urządzeniami BLE/IoT.

Uczy: uprawnień, komunikacji lokalnej

Legitymacja cyfrowa

Role: student, prowadzący, administrator.

Uczy: weryfikacji tożsamości, ról

PODZIAŁ

Sekcje technologiczne

Sekcja	Język	Bezpieczny magazyn (przykład)
Flutter	Dart	flutter_secure_storage
React Native	TypeScript	react-native-keychain
Kotlin Multiplatform	Kotlin	expect/actual → Keystore/Keychain
Android natywnie	Kotlin	Android Keystore
iOS natywnie	Swift	Keychain Services

2–3 osoby w każdej sekcji

iOS wymaga macOS i Xcode

Ten sam problem, różne rozwiązania — porównujemy co tydzień

PRACA W SEKCJACH · 35 MIN

Karta projektu

01

Koncepcja

Co robi aplikacja — w 3 zdaniach

02

Role

Kto korzysta i co może

03

Dane

Jakie dane i jak bardzo wrażliwe

04

Umowa

Gdzie u was jest każda funkcja

05

Architektura

Aplikacja, backend, usługi zewnętrzne

06

Zespół

Kto za co odpowiada

07

Plan do MVP

Co gotowe na zajęcia 2, 3, 4 i 5

08

Ryzyko

Co według was najłatwiej zaatakować

KARTA PROJEKTU · POLE 03

Klasyfikacja danych

Publiczne

Opis wydarzenia, cennik, regulamin

Ochrona: brak szczególnych wymagań

Wewnętrzne

Preferencje, historia wyszukiwań, ustawienia

Ochrona: izolacja od innych aplikacji

Poufne

E-mail, tokeny sesji, historia transakcji

Ochrona: bezpieczny magazyn, szyfrowanie

Szczególnie wrażliwe

Zdrowie, biometria, finanse, dokładna lokalizacja

Ochrona: minimalizacja; często nie przechowujemy lokalnie

NA ZAJĘCIA 2

Zadanie na następny tydzień

- ✓ Repozytorium (GitHub lub GitLab) z dostępem dla prowadzącego
- ✓ README z finalną kartą projektu
- ✓ Szkielet aplikacji, który się buduje i uruchamia
- ✓ Lektura: wprowadzenie do OWASP MASVS (mas.owasp.org)
- ✓ Szkic architektury: aplikacja, backend, usługi zewnętrzne